

	Total Controls Assessed	Total Non-Compliant Gaps	Highest Inherent Risk Score
	2	2	
	EXECUTIVE SUMMARY & KEY FINDINGS		
	An internal security gap assessment against the ISO 27001 framework has identified key high-risk vulnerabilities within our cloud infrastructure and identity access controls. Most notably, a lack of subnet isolation between staging and production environments (A.8.20) combined with missing multi-factor authentication on legacy admin tools (A.5.15) creates an elevated risk posture. Left unaddressed, these vulnerabilities expose live production financial PII to potential lateral threat movement, jeopardizing compliance alignment and risking an estimated \$1.5M in regulatory fines. Remediation pathways have been established to enforce AWS VPC micro-segmentation and universal SSO/MFA integration. Executing this roadmap immediately satisfies the security prerequisites necessary to securely unblock and sign our pending \$500k ARR enterprise contract.		
	Status	Count	
	Compliant	0	
	Partially Compliant	0	
	Non-Compliant	2	

Control ID	Control Name	ISO 2700:2022 Requirement	Current State	Compliance Status	Business Impact	Remediation Roadmap	Audit Evidence / Artifact Reference
A.8.20	Network Security	Networks and network devices shall be secured, managed, and controlled to protect information in systems and applications.	Apex relies entirely on flat AWS default security groups. Production container workloads (EKS) and staging/development microservices share the same VPC without network ACL isolation or internal subnet boundaries.	Non-Compliant	A flat network topology massively increases the blast radius of a breach. A compromise in the less-secure staging environment allows an attacker to pivot directly into production databases, exposing customer financial PII. This creates catastrophic liability under FinTech privacy mandates and directly violates the SLA requirements needed to sign our pending \$500k enterprise contract.	1. Re-architect AWS infrastructure into isolated VPCs for Staging and Production. 2. Implement AWS VPC Peering with strict Security Group micro-segmentation. 3. Enforce network policies within EKS to restrict cross-environment pod communication.	1. AWS VPC Topology Diagram (v2, 1_Draft) showing shared staging/prod subnets. 2. Exported AWS Security Group configuration JSON for Cluster-VPC. 3. IAM policy review logs indicating lack of network segmentation boundaries.
A.5.15	Access Control	Rules to control physical and logical access to information and other associated assets shall be established and implemented based on business and information security requirements.	MFA is not strictly enforced across all internal corporate tools. Several legacy admin panels and third-party SaaS applications rely on single-factor password authentication without integration into a centralized Single Sign-On (SSO) provider.	Non-Compliant	Lack of mandatory MFA exposes corporate infrastructure to simple credential-stuffing and phishing attacks. A single compromised employee password could grant an attacker administrative access to internal tools, leading to unauthorized data modification, severe operational downtime, and a total breach of confidentiality that triggers mandatory legal notification requirements.	1. Mandate hardware or app-based MFA for all corporate and production systems. 2. Centralize identity management by migrating standalone application logins to an enterprise SSO provider (e.g., Okta or AWS IAM Identity Center). 3. Implement strict conditional access policies based on device compliance and location.	1. Okta SSO Application Integration Directory Report (showing missing legacy admin tools). 2. Screenshot of standalone database console login prompt lacking an MFA challenge field. 3. Current Corporate Password Policy PDF (last updated 2024, missing mandatory MFA clauses).

